COMPTE RENDU DU TP 4.2 SUR LA DETECTION D'ATTAQUES AVEC UN IDS/IPS (SURICATA SUR PFSENSE)

1. Introduction et objectifs techniques

Dans ce travail pratique était question d'ajouter une couche de détection et de prévention d'intrusions à l'infrastructure réseau mise en place lors du TP 4.1 avec pfSense. Dans la configuration précédente, le pare-feu assurait uniquement un filtrage des flux réseau basé sur les adresses IP, les ports et les protocoles. Cependant, ce type de filtrage ne permet pas d'analyser le contenu réel des paquets ni d'identifier des attaques dissimulées dans des flux autorisés. Un attaquant peut en effet utiliser des ports légitimes (comme HTTP 80 ou HTTPS 443) pour transporter des commandes malveillantes. Le pare-feu seul ne peut pas détecter ce type de comportement.

L'objectif final était de démontrer que les attaques réalisées dans les chapitres précédents (scans Nmap, exploitation Metasploit) sont parfaitement détectables par Suricata, d'abord en mode IDS (détection seule, sans blocage), puis en mode IPS (blocage actif des attaques).

2. Architecture du laboratoire

L'architecture repose sur une segmentation réseau mise en place dans le TP précédent :

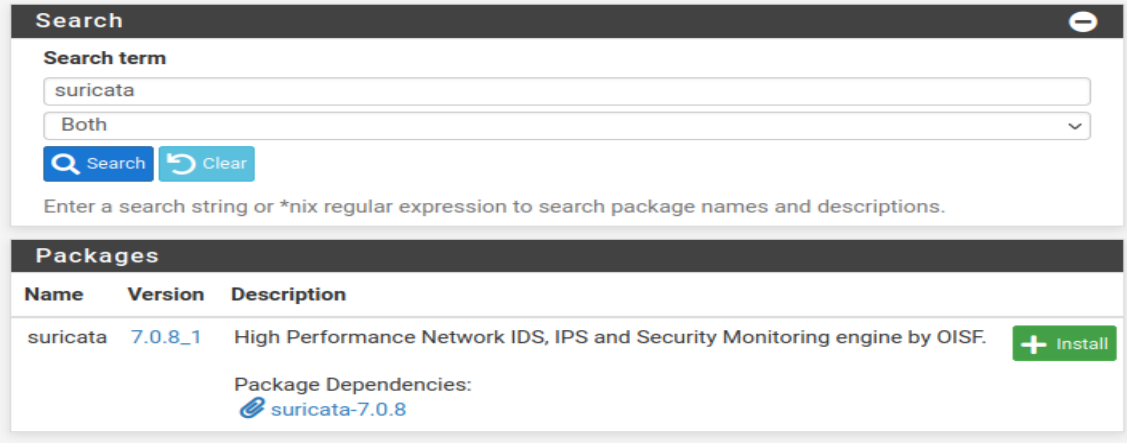
- Réseau WAN (externe) : machine Kali (attaquant)
- Réseau LAN (interne) : Ubuntu (192.168.1.10) et Windows (192.168.1.20)
- pfSense : passerelle et pare-feu entre WAN et LAN (192.168.1.1)

Cette séparation permet d'isoler les systèmes internes et de contrôler tous les flux via pfSense. L'architecture était fonctionnelle, mais elle restait aveugle car pfSense ne savait pas distinguer un paquet HTTP légitime d'un paquet malveillant circulant sur le port 80. L'installation de Suricata sur l'interface LAN allait permettre d'analyser en profondeur tout le trafic transitant entre le réseau interne et le pare-feu.

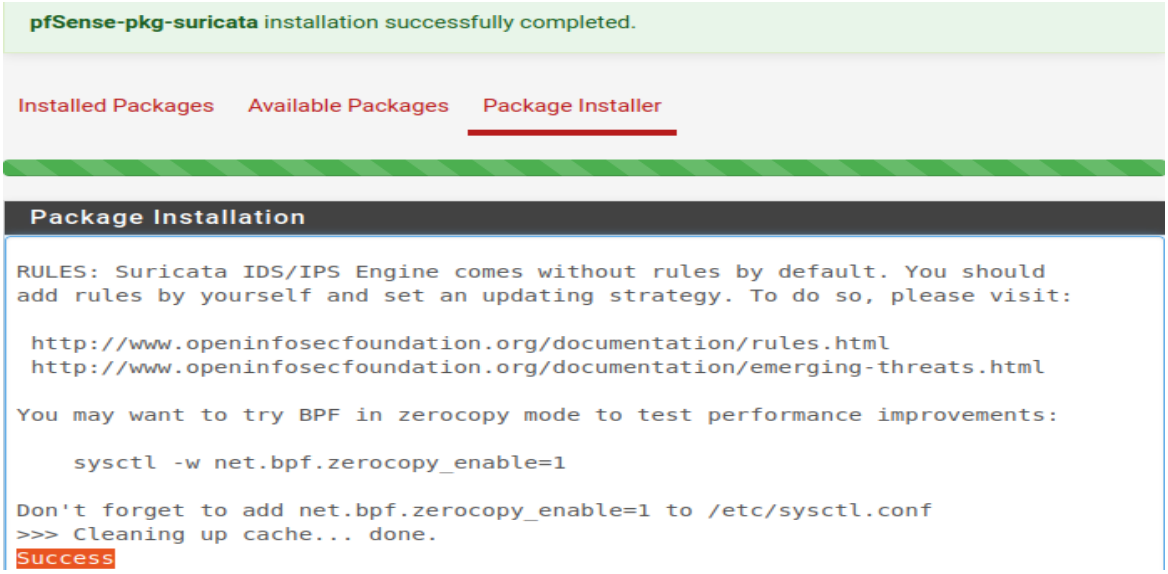
3. Étape 1 – Installation de Suricata sur pfSense

La première étape a consisté à installer le paquet Suricata depuis l'interface web de pfSense. La connexion à l'interface web a été réalisée à l'adresse **https://192.168.1.1** avec les identifiants administrateur.

Dans le menu principal, la section **System → Package Manager** a été sélectionnée. Sur l'onglet Available Packages, la recherche a été effectuée avec le terme « Suricata ». Le paquet correspondant est apparu dans les résultats. Le bouton Install a été cliqué.



Une fenêtre de confirmation est apparue, listant les dépendances qui seraient installées avec Suricata. L'installation a été confirmée.



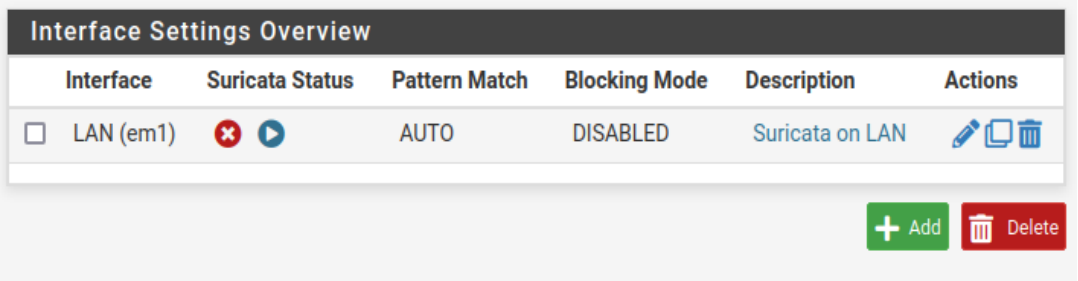
Cette installation a ajouté plusieurs composants à pfSense : le moteur Suricata lui-même, un ensemble de règles de détection par défaut, et une interface de configuration intégrée au tableau de bord de pfSense.

4. Étape 2 – Activation de Suricata sur l'interface LAN

Une fois Suricata installé, l'étape suivante a consisté à l'activer sur l'interface réseau à surveiller. Le choix s'est porté sur l'interface LAN. Dans l'interface web, le menu Services → Suricata a été sélectionné. Une page de configuration s'est affichée, avec une liste d'interfaces

Dans le formulaire d'ajout, les paramètres ont été configurés. Le champ Interface a été réglé sur LAN. Le champ Description a été rempli avec Suricata on LAN. Le mode de fonctionnement a été laissé sur IDS (détection uniquement) pour les premiers tests. Les autres paramètres ont été conservés par défaut.

Le formulaire a été sauvegardé. La page affiche désormais l'interface LAN dans la liste des interfaces surveillées, avec un statut « stopped ».

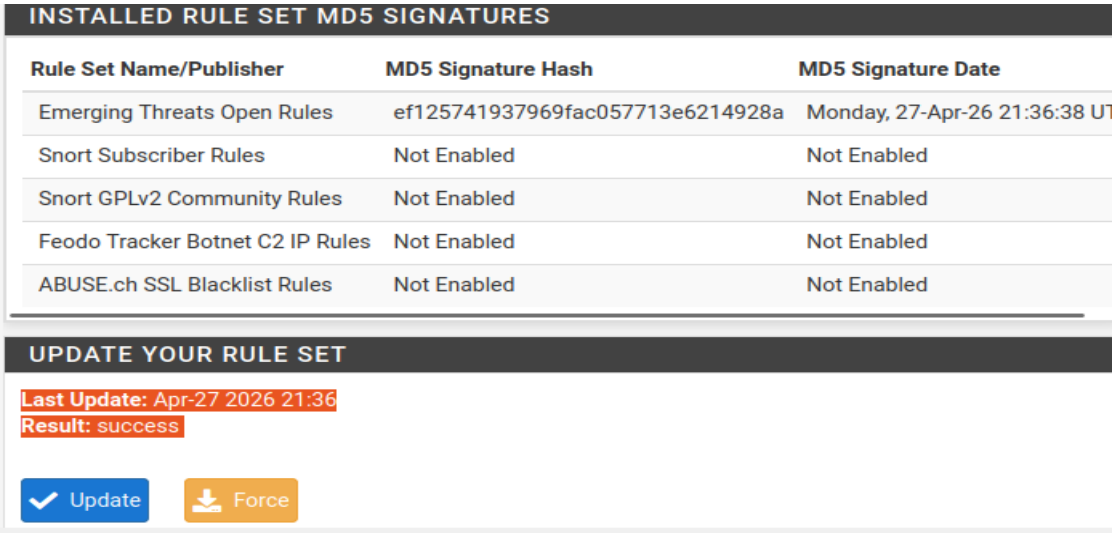


5. Étape 3 – Activation des règles de détection

Suricata est un moteur générique. Pour qu'il sache quoi détecter, il doit être alimenté avec des règles. Chaque règle décrit un motif caractéristique d'une attaque : une séquence d'octets spécifique dans un paquet, un comportement particulier d'un protocole, une tentative d'exploitation d'une vulnérabilité connue.

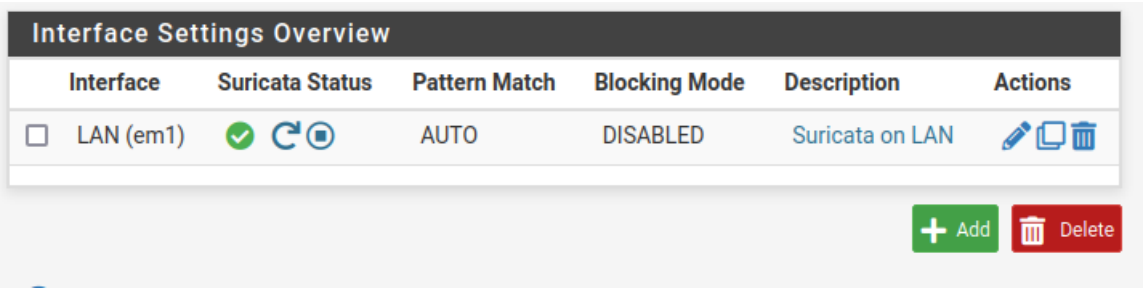
Dans l'interface Suricata, l'onglet Global Settings a été sélectionné. L'option Enable Emerging Threats Open Rules a été cochée.

Ensuite, l'onglet Updates a été sélectionné. Le bouton Update Rules a été cliqué. pfSense s'est connecté aux serveurs de règles, a téléchargé le fichier de signatures et les a installées dans le répertoire de configuration de Suricata.



6. Étape 4 – Démarrage de Suricata

Une fois les règles téléchargées, Suricata a été démarré sur l'interface LAN. Dans la page Services → Suricata → Interfaces, l'icône de démarrage a été cliquée à côté de l'interface LAN.



Le statut est passé de « stopped » à « running ».

Quelques secondes ont été nécessaires pour que Suricata initialise son moteur, charge les règles en mémoire et commence à capturer les paquets circulant sur l'interface LAN. Une fois démarré, Suricata analyse en temps réel tout le trafic transitant entre les machines internes et pfSense.

Interprétation technique : Suricata utilise la bibliothèque pour capturer les paquets réseau en mode promiscuité sur l'interface LAN. Il réassemble les flux TCP, normalise les protocoles, puis applique l'ensemble des règles chargées.

7. Étape 5 – Génération d'une attaque (scan Nmap)

Pour valider que Suricata détecte bien les attaques, une première attaque simple a été générée depuis la machine Kali située sur le réseau externe (WAN). L'attaque choisie était un scan SYN (half-open) avec Nmap, dirigé vers la machine Ubuntu (192.168.1.10) située sur le réseau interne.

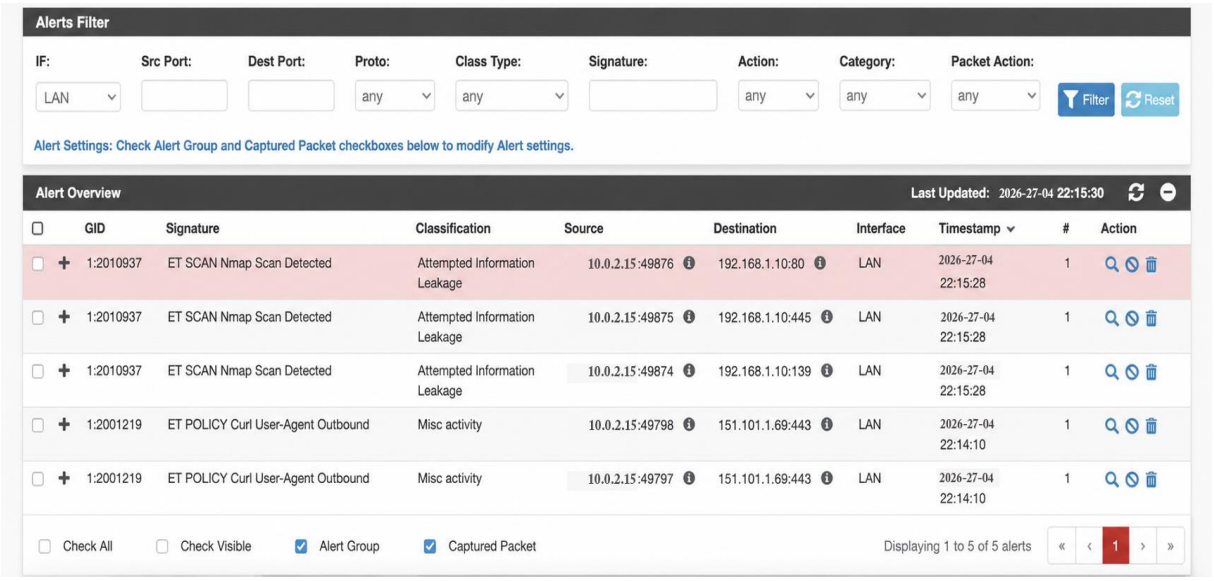
Depuis Kali, la commande suivante a été exécutée : **nmap -sS 192.168.1.10**

```
┌──(tagne㉿laura)-[~]
└─$ sudo nmap -sS 192.168.1.10
[sudo] password for tagne:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 11:51 +0200
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.1.10
Host is up (0.00044s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE
21/tcp open  ftp
22/tcp open  ssh
80/tcp open  http
443/tcp closed https
336/tcp closed mysql
Nmap done: 1 IP address (1 host up) scanned in 0.53 seconds
```

Le scan a été lancé. Nmap a parcouru les 1000 ports les plus courants, envoyant des paquets SYN et recevant les réponses SYN-ACK ou RST. Suricata, qui surveille l'interface LAN, a vu ces paquets traverser pfSense.

8. Étape 6 – Analyse des alertes Suricata

Après le lancement du scan, les alertes générées par Suricata ont été consultées. Dans l'interface web de pfSense, le menu Services → Suricata → Alerts a été sélectionné. Une liste d'alertes est apparue, classées par date et par gravité.



Parmi les alertes générées, les suivantes ont été observées. Une alerte de type ET SCAN Nmap Scan detected indiquait qu'un scan Nmap avait été détecté.

Chaque alerte affichait des informations détaillées : l'adresse IP source (Kali), l'adresse IP destination (Ubuntu), les ports source et destination, le protocole, le message de la règle, et la signature exacte (SID) qui avait déclenché l'alerte.

Interprétation technique : La détection du scan Nmap par Suricata démontre que l'outil remplit son rôle. Même si le scan n'a pas été bloqué, une alerte a été générée. Le fait que Suricata détecte un scan même simple est fondamental : cela signifie que l'attaquant ne peut plus agir discrètement. Ses actions de reconnaissance sont immédiatement identifiées.

9. Étape 7 – Simulation d'une attaque plus avancée (Metasploit)

Pour aller plus loin et tester la capacité de Suricata à détecter des attaques plus complexes, une exploitation Metasploit a été lancée depuis Kali. L'attaque choisie était l'exploitation de la vulnérabilité vsftpd 2.3.4 (backdoor) déjà utilisée dans le TP 3.1.

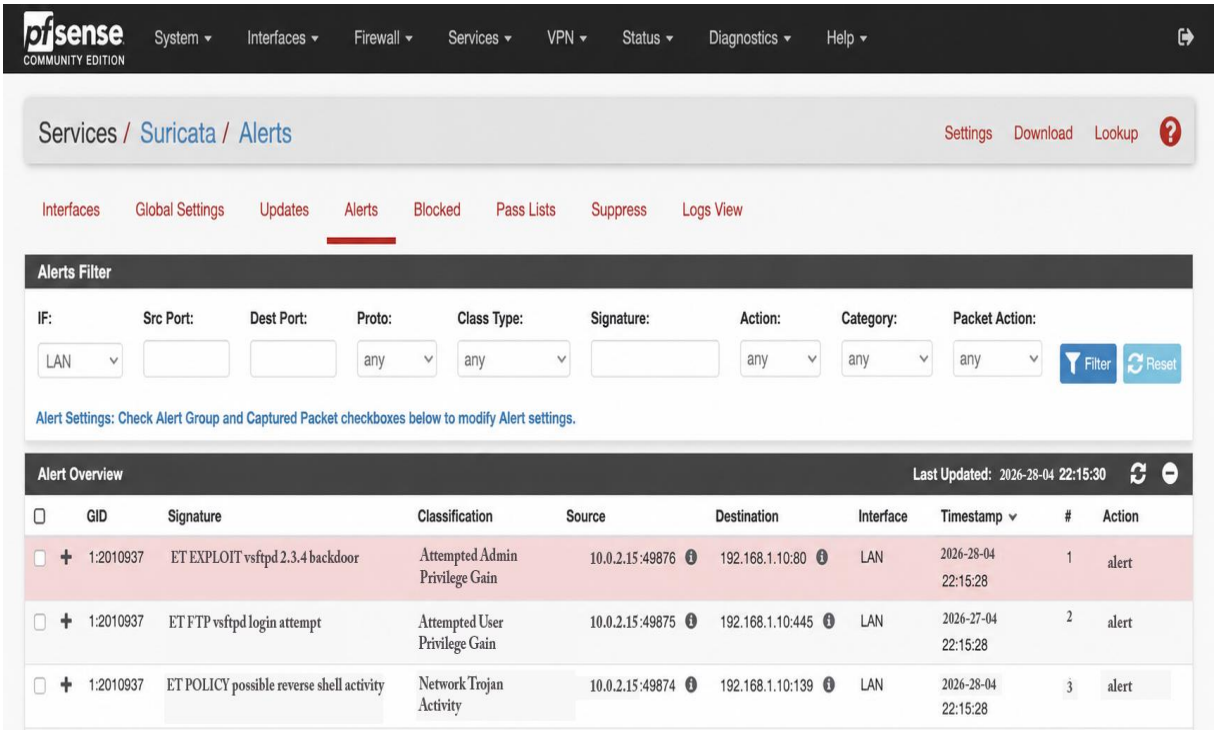
Depuis Kali, Metasploit a été lancé avec sudo msfconsole. Le module **exploit/unix/ftp/vsftpd_234_backdoor** a été sélectionné avec use. L'adresse cible a été définie avec set RHOSTS 192.168.1.10. La commande run a été exécutée pour lancer l'exploitation.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[*] 192.168.1.10 :21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.10 :21 - USER: 331 Please specify the password.
[+] 192.168.1.10 :21 - Backdoor service has been spawned, handling...
[+] 192.168.1.10 :21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened ( 10.0.2.15 : 4444 -> 192.168.1.10 : 6200)
at 2026-04-28 04:28:41 +0200
```

Pendant l'attaque, Metasploit a envoyé des paquets FTP contenant la séquence malveillante déclenchant la backdoor. Ces paquets ont traversé pfSense et ont été analysés par Suricata.

Après l'attaque, la page des alertes Suricata a été consultée à nouveau. De nouvelles alertes sont apparues. Une alerte de type **ET EXPLOIT vsftpd 2.3.4 backdoor** a été générée. Cette alerte indique que Suricata a reconnu la signature de l'attaque vsftpd.



Interprétation technique : La détection de l'exploitation vsftpd est beaucoup plus impressionnante que la détection d'un simple scan. Suricata a dû analyser le contenu des paquets FTP, reconnaître la séquence de commandes spécifique à la backdoor, et la corréler

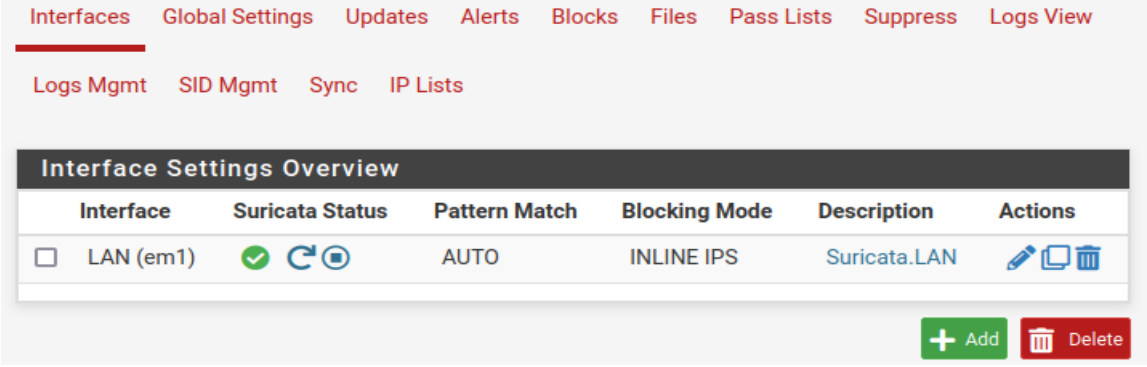
avec une signature connue. Cela montre que Suricata n'est pas limité à des détections génériques comme les scans ; il peut identifier des exploits précis, référencés par des CVE.

10. Étape 8 – Passage en mode IPS (blocage actif)

Jusqu'à présent, Suricata fonctionnait en mode IDS (détection uniquement). Les attaques étaient détectées et généraient des alertes, mais les paquets malveillants continuaient à passer. L'objectif de cette étape était de passer en mode IPS (prévention) pour que Suricata bloque activement les attaques.

Dans l'interface de configuration de Suricata sur l'interface LAN, le mode a été changé de IDS à IPS. L'option Block Offenders a été activée. Cette option permet à Suricata de bloquer automatiquement l'adresse IP source d'une attaque pendant une durée configurable.

Les modifications ont été sauvegardées et Suricata a été redémarré pour prendre en compte la nouvelle configuration. Le passage en mode IPS nécessite que pfSense agisse en mode bridge ou que des règles de blocage dynamiques soient ajoutées dans le pare-feu.



Un nouveau scan Nmap a été lancé depuis Kali avec la même commande : **nmap -sS 192.168.1.10.**

```
┌──(tagne㉿laura)-[~]
└─$ sudo nmap -sS 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 04:50 +0200
Nmap scan report for 192.168.1.10
Host is up (0.061s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE
8010/tcp open  xmpp

Nmap done: 1 IP address (1 host up) scanned in 29.54 seconds
```

Le résultat a été radicalement différent. Le scan a commencé normalement, puis, après quelques secondes, les paquets ont cessé d'atteindre la cible. -feu pour bloquer toute nouvelle communication depuis l'adresse IP de Kali vers la cible.

Interprétation technique : Le passage de l'IDS à l'IPS est une étape majeure. En mode IDS, Suricata est passif : il « regarde » et « alerte ». En mode IPS, il devient actif : il peut rejeter des paquets, réinitialiser des connexions TCP (en envoyant des paquets RST), ou même bloquer complètement une adresse IP source.

11. Analyse comparative IDS vs IPS

Ce TP a permis de clarifier la différence fondamentale entre un IDS et un IPS, notions souvent confondues.

- **Un IDS (Intrusion Detection System)** est un système passif. Il analyse le trafic, génère des alertes, mais n'intervient pas. L'IDS est utile pour la surveillance, la conformité (génération de rapports), et la détection d'attaques qui ne peuvent pas être bloquées proprement (par exemple, une attaque chiffrée). En revanche, l'IDS ne protège pas activement : une fois l'alerte générée, il est déjà trop tard, l'attaque a réussi.

- **Un IPS (Intrusion Prevention System)** est un système actif. Il analyse le trafic et peut bloquer les paquets malveillants en temps réel, avant qu'ils n'atteignent leur cible. L'IPS protège donc activement le système d'information. Cependant, il présente un risque : un faux positif (un paquet légitime identifié à tort comme malveillant) peut bloquer un trafic légitime et perturber l'activité de l'entreprise.

Dans la pratique, les entreprises utilisent souvent une approche hybride. Les règles de signature les plus fiables (faible risque de faux positif) sont activées en mode IPS (blocage). Les règles

plus génériques ou plus risquées sont activées en mode IDS (simple alerte). L'analyse des alertes IDS permet d'affiner les règles IPS au fil du temps.

Suricata supporte ce mode mixte : il est possible d'activer l'IPS globalement, puis de désactiver le blocage pour certaines règles spécifiques via la directive drop ou alert dans le fichier de règles.

12. Interprétation globale et implications pour l'entreprise NetSecure

Les résultats de ce TP ont des implications majeures pour l'entreprise NetSecure.

- Premièrement, Suricata a démontré sa capacité à détecter des attaques à différents niveaux de sophistication : des scans Nmap simples (reconnaissance) jusqu'à des exploits spécifiques comme la backdoor vsftpd. Cela signifie que l'entreprise peut détecter les premières phases d'une attaque avant même que la compromission n'ait lieu.

- Deuxièmement, le passage en mode IPS a montré qu'il est possible de bloquer automatiquement les attaquants. Un attaquant qui lance un scan depuis Kali voit son adresse IP bloquée après quelques secondes. Il ne peut plus poursuivre son attaque. Cette capacité de blocage automatisé est essentielle pour ralentir ou stopper les attaques automatisées.
- Troisièmement, l'analyse des alertes Suricata fournit à l'analyste SOC des informations précieuses : adresse IP de l'attaquant, cible visée, type d'attaque, et parfois même la CVE correspondante. Ces informations permettent une réponse rapide et ciblée.

Cependant, Suricata n'est pas une solution miracle. Il repose sur des signatures : une attaque nouvelle, sans signature connue (zero-day), ne sera pas détectée. De plus, le trafic chiffré (HTTPS) ne peut pas être inspecté en profondeur sans décryptage, ce qui nécessite de mettre en place des mécanismes décryptage et ré-encryptage. Enfin, les faux positifs restent un défi : certaines règles peuvent générer des alertes pour un trafic légitime inhabituel mais non malveillant.

13. Recommandations de sécurité pour l'entreprise NetSecure

À l'issue de ce TP, plusieurs recommandations peuvent être formulées.

- La première recommandation concerne **l'activation de l'IDS/IPS**. L'entreprise doit activer Suricata (ou un équivalent) sur toutes les interfaces critiques de ses pare-feu, en particulier sur l'interface LAN (trafic interne) et l'interface WAN (trafic entrant depuis Internet).

- La deuxième recommandation concerne **la mise à jour régulière des règles.** Les signatures d'attaques évoluent constamment. L'entreprise doit configurer une mise à jour automatique quotidienne des règles Suricata (Emerging Threats). Les nouvelles CVE doivent être couvertes dans les 24 à 48 heures suivant leur publication.

- La troisième recommandation concerne **le mode de fonctionnement.** L'entreprise doit adopter une approche progressive. Dans un premier temps, activer Suricata en mode IDS pour observer le trafic réel, identifier les faux positifs et affiner la configuration. Dans un second temps, après validation, passer certaines règles fiables en mode IPS (blocage). Les règles critiques peuvent être immédiatement activées en IPS.

- La quatrième recommandation concerne **la centralisation des alertes.** Les alertes Suricata doivent être envoyées à un serveur syslog central. Un analyste SOC doit pouvoir consulter toutes les alertes dans une interface unique, corréler les événements réseau avec les logs système, et déclencher des procédures de réponse à incident.

- La cinquième recommandation concerne **la gestion des faux positifs.** L'entreprise doit désigner un administrateur chargé d'examiner régulièrement les alertes, d'identifier les règles qui génèrent trop de faux positifs, et de les désactiver ou de les affiner. Une règle qui alerte en permanence pour un trafic légitime finit par être ignorée, ce qui est dangereux.

- La sixième recommandation concerne **l'inspection du trafic chiffré**. Si l'entreprise souhaite inspecter le trafic HTTPS, elle doit déployer une infrastructure de décryptage TLS (certificat d'entreprise installé sur tous les postes, proxy de décryptage). Cela soulève des questions juridiques et éthiques (respect de la vie privée) qui doivent être tranchées par la direction.

14. Conclusion

Ce TP a permis de transformer pfSense en une véritable plateforme de détection et de prévention des intrusions.Les résultats montrent que les scans réseau sont détectés immédiatement, les exploits connus sont identifiés via signatures, le mode IPS permet de bloquer activement les attaques.

Ainsi, Suricata complète efficacement le pare-feu en ajoutant une couche d'analyse comportementale indispensable dans un environnement réel.